

Manual 24 — Implementação Controlada da NIS2

Tradução de projeto pt-BR — não oficial

****Ordem da série:**** 24

****Base principal da UE:**** Diretiva (UE) 2022/2555 (NIS2)

****Regra de camadas de fontes:**** as obrigações da Diretiva, a legislação de transposição dos Estados-Membros, os atos de execução da Comissão, as orientações da ENISA ou de autoridades competentes, os requisitos setoriais, os requisitos contratuais e os procedimentos internos permanecem distintos.

****Limite:**** Este manual é um auxílio de implementação; não constitui assessoria jurídica, aprovação regulatória, certificação nem substitui a legislação nacional aplicável ou as instruções de uma autoridade competente.

01. Aplicabilidade e classificação de entidades

Determine se cada entidade jurídica e serviço está no escopo da NIS2 usando a Diretiva, os critérios setoriais dos Anexos I/II, as regras e exceções de limiar de porte, as decisões de identificação dos Estados-Membros e a medida nacional de transposição aplicável. Distinga entidades essenciais, entidades importantes e entidades fora de escopo; não infira a classificação apenas pelo nome do setor.

****Registro de controle:**** camada de fonte e jurisdição; fatos da entidade/serviço; fundamento da classificação; responsável jurídico/compliance; localização da evidência; método de revisão; rota de exceção ou remediação; e gatilho de reavaliação diante de mudanças organizacionais, de serviço, de porte, de propriedade, de setor ou legais.

02. Jurisdição, estabelecimento e escopo transfronteiriço

Identifique o Estado-Membro ou os Estados-Membros com jurisdição, estabelecimentos relevantes, qualquer representante exigido na UE, localizações de serviços e dependências transfronteiriças. Resolva conflitos ou incertezas por meio do arcabouço nacional aplicável e dos canais da autoridade competente, em vez de presumir uma única rota de apresentação para toda a UE.

****Registro de controle:**** fonte jurisdicional; mapa de estabelecimentos e serviços; responsável jurídico; procedimento de determinação; evidência de suporte; validação periódica; escalonamento de jurisdição não resolvida; e reavaliação diante de reestruturação ou entrada em mercado.

03. Governança de entidades essenciais e importantes

Mantenha um modelo de governança documentado apropriado à classificação da entidade. Os órgãos de administração devem aprovar as medidas de gestão de riscos de cibersegurança quando a implementação aplicável da NIS2 assim exigir e supervisionar sua implementação; os registros de governança devem demonstrar decisões, questionamento, responsabilidade, escalonamento e acompanhamento da remediação.

****Registro de controle:**** Artigo 20/camada de fonte nacional aplicável; aplicabilidade ao órgão de administração; executivo e órgão de governança responsáveis; procedimento de aprovação e supervisão; atas ou evidência de decisão; revisão da efetividade da governança; responsável pela remediação; e reavaliação após mudança material de controle ou liderança.

04. Competência e treinamento do órgão de administração

Forneça aos membros do órgão de administração treinamento suficiente para identificar riscos de cibersegurança e avaliar práticas de gestão de riscos de cibersegurança e seu impacto sobre os serviços. Mantenha treinamento da força de trabalho adequado às funções, exposição e requisitos nacionais de implementação.

****Registro de controle:**** camada de fonte; população no escopo; responsável pelo treinamento; currículo e procedimento de conclusão; evidência de participação e competência; revisão de efetividade; remediação de treinamento vencido; e reavaliação após mudanças de função, ameaça ou regulação.

05. Estrutura de gestão de riscos de cibersegurança

Mantenha uma estrutura proporcional e de abordagem de todos os riscos para gestão de riscos de cibersegurança que cubra sistemas de redes e informação usados nas operações ou prestação de serviços. Defina critérios de risco, apetite ou tolerância, cadência de avaliação, opções de tratamento, exceções, responsabilidade por controles, dependências e aceitação de risco residual.

****Registro de controle:**** Artigo 21 da Diretiva/fonte nacional; sistemas e serviços no escopo; responsável pelo risco; procedimento de avaliação e tratamento; registro de riscos e evidência de aceitação; revisão de efetividade; escalonamento de tratamentos vencidos; e reavaliação após mudança significativa ou incidente.

06. Políticas de análise de riscos e segurança de sistemas de informação

Mantenha políticas aprovadas para análise de riscos de cibersegurança e segurança de sistemas de informação. As políticas devem traduzir requisitos legais e de risco em responsabilidades exigíveis, controles mínimos, exceções, expectativas de evidência e ciclos de revisão.

****Registro de controle:**** fonte aplicável; escopo da política; responsável pela política; procedimento de aprovação/mudança; artefato de política controlado; revisão de conformidade; processo de exceção/remediação; e reavaliação programada ou acionada por eventos.

07. Escopo de ativos, serviços, dados e dependências

Mantenha inventários atuais de entidades jurídicas, serviços empresariais, sistemas de redes e informação, ativos de informação, dados, interfaces, caminhos privilegiados, fornecedores críticos, instalações e dependências a montante/jusante. Mapeie ativos técnicos materiais aos serviços e responsáveis.

****Registro de controle:**** camada de fonte; aplicabilidade do inventário; responsável por ativo/serviço; procedimento de descoberta e reconciliação; evidência de inventário e mapa de dependências; testes de completude; remediação de ativos ausentes; e reavaliação após aquisição, implantação, retirada ou mudança de arquitetura.

08. Tratamento de incidentes

Mantenha capacidades de tratamento de incidentes que cubram detecção, triagem, avaliação de severidade, comando, contenção, erradicação, recuperação, preservação de evidência, comunicação, roteamento jurídico/regulatório e lições aprendidas. Mantenha os modelos internos de severidade separados das determinações legais de significância.

****Registro de controle:**** fontes jurídicas e internas aplicáveis; população de incidentes; comandante do incidente e responsável regulatório; procedimento de resposta; registro de ticket/linha do tempo/evidência; exercícios e revisão pós-incidente; rota de ação corretiva; e reavaliação após incidentes ou exercícios materiais.

09. Continuidade de negócios, backup, recuperação de desastres e gestão de crises

Implemente controles de continuidade adequados ao serviço e ao risco cibernético, incluindo gestão de backup, recuperação de desastres, gestão de crises, processamento alternativo, prioridades de restauração, dependências de recuperação, comunicação e validação do retorno ao serviço.

****Registro de controle:**** Artigo 21/fonte nacional; serviços e sistemas críticos; responsável por continuidade; procedimento de execução BCP/DR; evidência de backup e exercícios; testes de objetivos de recuperação; remediação de lacunas; e reavaliação após mudança de serviço ou dependência.

10. Segurança da cadeia de suprimentos

Trate os riscos de cibersegurança decorrentes de fornecedores diretos e prestadores de serviços, incluindo vulnerabilidades específicas de cada fornecedor e a qualidade geral e as práticas de cibersegurança dos prestadores. Avalie concentração, dependência, subcontratação, localização, acesso, tratamento de dados, resiliência e viabilidade de saída de forma proporcional ao risco.

****Registro de controle:**** camada de fonte aplicável; escopo de fornecedor/serviço; responsável por risco de terceiros; procedimento de due diligence e monitoramento; repositório de avaliação/contrato/evidência; revisão periódica e acionada por eventos; rota de remediação ou saída; e reavaliação diante de mudança material ou incidente do fornecedor.

11. Aquisição, desenvolvimento e manutenção seguros

Aplique controles de segurança em aquisição, arquitetura, desenvolvimento, integração, testes, implantação, configuração, mudança, aplicação de patches, manutenção e retirada de sistemas de redes e informação. Incorpore requisitos de segurança e critérios de aceitação antes do uso em produção.

****Registro de controle:**** camada de fonte; sistemas e projetos no escopo; responsável de engenharia/produto; procedimento de ciclo de vida seguro; evidência de projeto/teste/mudança; testes de efetividade dos controles; remediação de defeitos/exceções; e reavaliação após mudança significativa de arquitetura, software ou ameaça.

12. Tratamento e divulgação de vulnerabilidades

Mantenha processos de descoberta, recebimento, validação, priorização, remediação, divulgação e coordenação de vulnerabilidades. Acompanhe exposição explorável, controles compensatórios, serviços afetados, dependências de fornecedores, prazos, aceitação de risco e evidência de encerramento.

****Registro de controle:**** Artigo 21/fontes nacionais e de divulgação aplicáveis; aplicabilidade de ativos; responsável por vulnerabilidades; procedimento de tratamento/divulgação; evidência de scanner/ticket/aviso; verificação de remediação; escalonamento de exceções; e reavaliação diante de nova explorabilidade ou inteligência de ameaças.

13. Avaliação da efetividade das medidas de cibersegurança

Estabeleça políticas e procedimentos para avaliar se as medidas de gestão de riscos de cibersegurança são efetivas. Use testes de controles, validação técnica, métricas, auditorias, exercícios, revisão independente quando apropriado e remediação baseada em evidências, e não apenas na existência de políticas.

****Registro de controle:**** fonte aplicável; população de controles; responsável por assurance; metodologia de testes; resultados e evidência de suporte; validação de problemas; rota de remediação/reteste; e reavaliação baseada em risco, falha ou mudança material.

14. Higiene cibernética básica e treinamento em cibersegurança

Defina e aplique práticas básicas de higiene cibernética, incluindo configuração segura, aplicação de patches, proteção contra malware, resistência a phishing, higiene de credenciais, proteções de estações de trabalho/servidores, administração segura e treinamento em cibersegurança baseado em função.

****Registro de controle:**** camada de fonte; aplicabilidade à força de trabalho/sistemas; responsáveis por operações de segurança e treinamento; procedimento operacional; evidência de configuração/treinamento; amostragem ou testes técnicos; rota de remediação; e reavaliação após mudanças de ameaça, tecnologia ou força de trabalho.

15. Criptografia e cifragem

Mantenha políticas e procedimentos que governem criptografia e, quando apropriado, cifragem. Defina algoritmos e protocolos aprovados, geração/armazenamento/rotação/revogação de chaves, gestão de certificados, tratamento de segredos, requisitos para dados em repouso/em trânsito, exceções e migração de mecanismos obsoletos.

****Registro de controle:**** fonte aplicável e base de risco; sistemas/dados no escopo; responsável pelo controle criptográfico; procedimentos de chaves e certificados; evidência de configuração/gestão de chaves; revisão técnica; rota de exceção/remediação; e reavaliação após mudança criptográfica ou de plataforma.

16. Segurança de recursos humanos, controle de acesso e gestão de ativos

Aplique controles de segurança de pessoal adequados à função e ao risco, acesso de menor privilégio, processos de entrada/movimentação/saída, governança de acesso privilegiado, revisão periódica de acessos, segregação de funções, atribuição, devolução e propriedade de ativos.

****Registro de controle:**** camada de fonte; força de trabalho/contas/ativos no escopo; responsáveis por IAM/RH/ativos; procedimento de ciclo de vida; evidência de acesso e ativos; recertificação e amostragem; rota de exceção/remediação; e reavaliação após mudança de função, emprego, privilégio ou ativo.

17. Autenticação multifator e comunicações seguras

Use autenticação multifator ou soluções de autenticação contínua, comunicações seguras de voz/vídeo/texto e sistemas seguros de comunicação de emergência quando apropriado segundo a implementação aplicável da NIS2 e a avaliação de riscos. Documente quando uma medida não for aplicável ou viável se a fonte governante permitir tal qualificação.

****Registro de controle:**** camada de fonte; aplicabilidade a usuários/sistemas/comunicações; responsável por IAM ou comunicações; procedimento de implementação; evidência de configuração e cobertura; testes técnicos; rota de exceção/remediação; e reavaliação após mudança de arquitetura ou risco.

18. Registro, monitoramento e detecção

Mantenha registro e monitoramento baseados em risco suficientes para detectar atividade anômala, acesso não autorizado, falhas de integridade, interrupção de serviço, falha de controles de segurança e eventos materiais de fornecedores. Proteja a integridade dos logs, sincronize o tempo, defina retenção e preserve evidência necessária para investigação e reporte.

****Registro de controle:**** fonte aplicável; sistemas/serviços no escopo; responsável por SOC/operações; procedimento de monitoramento; evidência de fontes de logs/casos de uso; testes de cobertura e detecção; remediação de lacunas; e reavaliação após mudança de sistema, ameaça ou incidente.

19. Determinação de incidente significativo

Mantenha um processo juridicamente controlado para determinar se um incidente é significativo conforme o Artigo 23 da Diretiva, a medida nacional de transposição aplicável e qualquer ato de execução diretamente aplicável. Não use apenas a severidade interna como gatilho legal. Para entidades dentro do Regulamento de Execução (UE) 2024/2690 da Comissão, aplique seus critérios de significância somente dentro do escopo de entidades definido por esse Regulamento.

****Registro de controle:**** fonte jurídica exata e escopo da entidade; fatos do incidente; responsável pela decisão regulatória; planilha de determinação; evidência e fundamento; revisão jurídica/compliance; rota de correção/escalonamento; e reavaliação conforme evoluem os fatos do incidente.

20. Alerta precoce e notificação de incidentes

Para entidades essenciais e importantes sujeitas à sequência de reporte da Diretiva, mantenha capacidade de enviar um alerta precoce sem demora indevida e, em qualquer caso, dentro de 24 horas após tomar conhecimento de um incidente significativo, seguido de uma notificação do incidente sem demora indevida e, em qualquer caso, dentro de 72 horas, sujeito ao roteamento nacional aplicável e a qualquer regra especial legalmente aplicável. Preserve a regra distinta de 24 horas para prestadores de serviços de confiança quando aplicável e revalide todas as instruções de apresentação no momento do uso operacional.

****Registro de controle:**** fonte/regra de prazo vigente; aplicabilidade de entidade e incidente; responsável pelo reporte; procedimento de início do relógio e apresentação; evidência de apresentação com carimbo de tempo; revisão de prazo/qualidade; remediação de apresentação tardia ou defeituosa; e reavaliação diante de novos fatos ou instruções da autoridade.

21. Relatórios intermediários, de progresso e finais de incidentes

Mantenha capacidade de fornecer um relatório intermediário quando solicitado e um relatório final no máximo um mês após a notificação do incidente, sujeito à regra da Diretiva para relatório de progresso de incidente em curso e à implementação nacional aplicável. O relatório final deve registrar severidade/impacto, ameaça provável ou causa raiz, mitigação e impacto transfronteiriço quando aplicável.

****Registro de controle:**** fonte exata de reporte; aplicabilidade do incidente; responsável pelo reporte regulatório; procedimento de preparação; relatório apresentado e evidência de recebimento; revisão de completude; rota de correção/remediação; e reavaliação até a conclusão do tratamento do incidente e do encerramento regulatório.

22. Comunicações aos destinatários de serviços afetados

Quando aplicável, comunique sem demora indevida aos destinatários de serviços potencialmente afetados por uma ameaça cibernética significativa as medidas ou remédios que podem adotar e, quando apropriado, informe-os sobre a própria ameaça. Coordene funções regulatórias, jurídicas, de segurança, clientes, privacidade e comunicações para que os avisos sejam precisos e não comprometam a resposta.

****Registro de controle:**** fonte jurídica e aplicabilidade aos destinatários; responsável por comunicações; procedimento de aprovação e entrega; evidência de aviso/destinatário/entrega; revisão de tempestividade e completude; rota de correção; e reavaliação conforme a ameaça ou impacto mudem.

23. Registro de entidades e dados voltados às autoridades

Mantenha os dados exigidos para as listas aplicáveis de entidades dos Estados-Membros e, para os tipos de entidades abrangidos pelo Artigo 27 da Diretiva, as informações que suportam o processo de registro da ENISA por meio dos pontos de contato únicos nacionais. Acompanhe nomes, setor/tipo, estabelecimentos ou detalhes do representante, informações de contato atuais, jurisdições de serviço, faixas de IP quando exigidas e obrigações de notificação de mudanças conforme a fonte governante.

****Registro de controle:**** fonte nacional/UE exata; aplicabilidade do registro; responsável jurídico/compliance; procedimento de apresentação/mudança; dados apresentados e evidência de recebimento; revisão periódica de exatidão; rota de correção; e reavaliação após mudanças corporativas, de contato, rede ou serviço.

24. Controles de dados de registro de nomes de domínio

Quando se aplicarem o Artigo 28 da Diretiva e a legislação nacional de implementação, mantenha dados de registro de nomes de domínio exatos e completos com due diligence e controles aplicáveis de proteção de dados. Mantenha procedimentos de coleta, verificação, divulgação, acesso e retenção alinhados ao papel jurídico preciso do registro de TLD ou do prestador de serviços de registro de nomes de domínio.

****Registro de controle:**** fonte e aplicabilidade do papel; responsável pelos dados; procedimento de coleta/verificação/divulgação; evidência de banco de dados e solicitações; revisão de exatidão/privacidade; rota de remediação; e reavaliação após mudança jurídica, de sistema ou de dados de registro.

25. Sobreposições setoriais e do regulamento de execução

Mantenha uma sobreposição controlada para requisitos específicos do setor e do tipo de entidade. O Regulamento de Execução (UE) 2024/2690 da Comissão deve ser aplicado às entidades relevantes que define —como determinados provedores DNS/TLD, nuvem, data center, CDN, serviços gerenciados, serviços de segurança gerenciados, mercados online/busca/plataformas sociais e prestadores de serviços de confiança— e não generalizado para entidades NIS2 não relacionadas.

****Registro de controle:**** fonte da sobreposição e tipo de entidade; decisão de aplicabilidade; responsável setorial/regulatório; procedimento de mapeamento; evidência requisito-para-controle; revisão periódica de fontes; remediação de lacunas; e reavaliação após mudança de serviço, classificação ou legislação.

26. Mapeamento de controles do Regulamento de Execução 2024/2690 da Comissão

Para entidades dentro do Regulamento (UE) 2024/2690, mapeie os requisitos técnicos e metodológicos do Anexo para controles operacionais e evidências. Quando esse Regulamento permitir que um requisito seja aplicado apenas quando apropriado, aplicável ou viável, documente de modo compreensível qualquer fundamento de não aplicação e preserve a base de risco de suporte.

****Registro de controle:**** disposição exata do Regulamento; aplicabilidade à entidade relevante; responsável pelo controle; procedimento de mapeamento e implementação; matriz de controle/evidência; revisão de conformidade e efetividade; rota de remediação ou não aplicação documentada; e reavaliação após mudança de risco ou serviço.

27. Evidência de fornecedores e assurance da cadeia

Mantenha evidência demonstrando que os requisitos de segurança de fornecedores operam na prática, e não apenas em linguagem contratual. Colete e avalie descrições de serviços, localizações de dados/acesso, atestações de segurança, evidência de testes, histórico de incidentes, vulnerabilidades, capacidades de continuidade, subcontratados, mudanças materiais, concentração e prontidão de saída de acordo com o risco.

****Registro de controle:**** fonte e escopo do fornecedor; responsável por terceiros; procedimento de coleta de evidência; dossiê do fornecedor; método de revisão/testes; escalonamento/remediação de problemas; e reavaliação em renovação, mudança material, incidente ou nova inteligência.

28. Exercícios, testes e validação de remediação

Exercite resposta a incidentes, continuidade, gestão de crises, comunicações, interrupção de fornecedores, recuperação e tomada de decisão sob cenários plausíveis. Valide a remediação por meio de reteste ou outra evidência apropriada ao achado; não encerre problemas materiais com base apenas em declaração.

****Registro de controle:**** fonte/base de risco; escopo testado; responsável por assurance ou resiliência; procedimento de exercício/teste; plano/resultados/evidência; validação de achados; rota de remediação e reteste; e reavaliação com base no resultado do teste ou mudança de risco.

29. Métricas, limiares e reporte gerencial

Defina métricas úteis para decisão sobre risco, incidentes, prontidão de reporte, vulnerabilidades, aplicação de patches, acesso, treinamento, exposição de fornecedores, continuidade, testes, exceções e remediação. Mantenha limiares operacionais distintos dos critérios jurídicos de significância de incidentes e documente a lógica de escalonamento.

****Registro de controle:**** fonte e base de risco; população de métricas; responsável pela métrica; procedimento de cálculo/reporte; dados-fonte e relatórios; revisão de qualidade/efetividade dos dados; rota de correção; e reavaliação quando riscos, sistemas ou limiares legais mudarem.

30. Exceções, ações corretivas e prontidão para supervisão

Opere um ciclo de vida controlado de exceções e remediação com base de risco, responsável, aprovador, controles compensatórios, prazo, evidência, gatilho de reavaliação e verificação de encerramento. Preserve registros necessários para apoiar supervisão por autoridades competentes e interações de enforcement conforme a classificação da entidade e a legislação nacional aplicável.

****Registro de controle:**** fonte governante; aplicabilidade do problema/exceção; responsáveis por risco e remediação; fluxo de trabalho; evidência de aprovação e encerramento; revisão independente ou gerencial; rota de escalonamento/reteste; e reavaliação até o encerramento verificado.

31. Localização e controle de fontes jurídicas

Traduza somente a partir de uma fonte inglesa exata e congelada. Preserve termos jurídicos, classificações de entidades, distinções de camadas de fontes, lógica de significância de incidentes, etapas e prazos de reporte, escopo do regulamento de execução, ressalvas de legislação nacional e condição de tradução não oficial. Referências a fontes jurídicas podem ser localizadas para legibilidade, mas devem permanecer rastreáveis à mesma disposição controladora.

****Registro de controle:**** identidade da fonte congelada; aplicabilidade de locale; responsável/revisor de localização; procedimento de tradução controlada; evidência de paridade; revisão semântica e estrutural; rota de correção/retradução; e reavaliação após qualquer mudança do inglês ou da fonte.

32. Vigilância de fontes, proveniência, acessibilidade e publicação

Antes de congelar candidatos e publicar, revalide o texto vigente da Diretiva (UE) 2022/2555, as medidas nacionais de transposição aplicáveis ao caso de uso pretendido, os atos de execução da Comissão incluindo o Regulamento (UE) 2024/2690 quando relevante, materiais vigentes da ENISA e autoridades competentes, instruções de reporte de incidentes e sobreposições setoriais. Vincule o commit exato da fonte inglesa, fontes localizadas, binários DOCX/PDF, identidades SHA-256, QA de renderização e acessibilidade, resultados de segurança de workflows, evidência de revisão substantiva quando exigida, estado de publicação do predecessor e reconciliação do catálogo/registo de releases. Se permanecer sem solução qualquer defeito material de fonte, aplicabilidade, localização, integridade, empacotamento, acessibilidade, proveniência, segurança ou substância, a publicação falha de forma fechada.

****Registro de controle:**** conjunto de fontes no momento do release; aplicabilidade da publicação; responsável pelo release; procedimento de candidato/reconciliação; manifesto de proveniência e evidência de QA; revisão do head exato; rota de remediação/regeneração; e reavaliação após qualquer mudança material de fonte ou artefato.

Mínimo de implementação controlada

Cada capítulo deve ser implementado por meio de evidência apropriada aos fatos e à jurisdição da organização. No mínimo, os registros devem identificar a camada de fonte controladora, decisão de aplicabilidade, responsável, procedimento operacional, objeto e localização da evidência, método de revisão ou teste, rota de exceção/remediação e gatilho de reavaliação. A legislação nacional de transposição e as instruções da autoridade competente controlam quando impuserem requisitos específicos de jurisdição que diferirem desta arquitetura genérica de implementação.